

Automating Recon

While manual reconnaissance can be effective, it can also be time-consuming and prone to human error. Automating web reconnaissance tasks can significantly enhance efficiency and accuracy, allowing you to gather information at scale and identify potential vulnerabilities more rapidly.

Why Automate Reconnaissance?

Automation offers several key advantages for web reconnaissance:

- **Efficiency:** Automated tools can perform repetitive tasks much faster than humans, freeing up valuable time for analysis and decision-making.
- **Scalability:** Automation allows you to scale your reconnaissance efforts across a large number of targets or domains, uncovering a broader scope of information.
- **Consistency:** Automated tools follow predefined rules and procedures, ensuring consistent and reproducible results and minimising the risk of human error.
- **Comprehensive Coverage:** Automation can be programmed to perform a wide range of reconnaissance tasks, including DNS enumeration, subdomain discovery, web crawling, port scanning, and more, ensuring thorough coverage of potential attack vectors.
- **Integration:** Many automation frameworks allow for easy integration with other tools and platforms, creating a seamless workflow from reconnaissance to vulnerability assessment and exploitation.

Reconnaissance Frameworks

These frameworks aim to provide a complete suite of tools for web reconnaissance:

- **FinalRecon:** A Python-based reconnaissance tool offering a range of modules for different tasks like SSL certificate checking, Whois information gathering, header analysis, and crawling. Its modular structure enables easy customisation for specific needs.
- **Recon-ng:** A powerful framework written in Python that offers a modular structure with various modules for different reconnaissance tasks. It can perform DNS enumeration, subdomain discovery, port scanning, web crawling, and even exploit known vulnerabilities.
- **theHarvester:** Specifically designed for gathering email addresses, subdomains, hosts, employee names, open ports, and banners from different public sources like search engines, PGP key servers, and the SHODAN database. It is a command-line tool written in Python.
- **SpiderFoot:** An open-source intelligence automation tool that integrates with various data sources to collect information about a target, including IP addresses, domain names, email addresses, and social media profiles. It can perform DNS lookups, web crawling, port scanning, and more.
- **OSINT Framework:** A collection of various tools and resources for open-source intelligence gathering. It covers a wide range of information sources, including social media, search engines, public records, and more.

FinalRecon

FinalRecon offers a wealth of recon information:

- **Header Information:** Reveals server details, technologies used, and potential security

- **Header Information:** Reveals server details, technologies used, and potential security misconfigurations.
- **Whois Lookup:** Uncovers domain registration details, including registrant information and contact details.
- **SSL Certificate Information:** Examines the SSL/TLS certificate for validity, issuer, and other relevant details.
- **Crawler:**
 - HTML, CSS, JavaScript: Extracts links, resources, and potential vulnerabilities from these files.
 - Internal/External Links: Maps out the website's structure and identifies connections to other domains.
 - Images, robots.txt, sitemap.xml: Gathers information about allowed/disallowed crawling paths and website structure.
 - Links in JavaScript, Wayback Machine: Uncovers hidden links and historical website data.
- **DNS Enumeration:** Queries over 40 DNS record types, including DMARC records for email security assessment.
- **Subdomain Enumeration:** Leverages multiple data sources (crt.sh, AnubisDB, ThreatMiner, CertSpotter, Facebook API, VirusTotal API, Shodan API, BeVigil API) to discover subdomains.
- **Directory Enumeration:** Supports custom wordlists and file extensions to uncover hidden directories and files.
- **Wayback Machine:** Retrieves URLs from the last five years to analyse website changes and potential vulnerabilities.

Installation is quick and easy:

```

Automating Recon

dbcyp0n@htb[/htb]$ git clone https://github.com/thewhiteh4t/FinalRecon.git
dbcyp0n@htb[/htb]$ cd FinalRecon
dbcyp0n@htb[/htb]$ pip3 install -r requirements.txt
dbcyp0n@htb[/htb]$ chmod +x ./finalrecon.py
dbcyp0n@htb[/htb]$ ./finalrecon.py --help

usage: finalrecon.py [-h] [--url URL] [--headers] [--sslinfo] [--whois]
                  [--crawl] [--dns] [--sub] [--dir] [--wayback] [--ps]
                  [--full] [-nb] [-dt DT] [-pt PT] [-T T] [-w W] [-r] [-s]
                  [-sp SP] [-d D] [-e E] [-o O] [-cd CD] [-k K]

FinalRecon - All in One Web Recon | v1.1.6

optional arguments:
  -h, --help            show this help message and exit
  --url URL              Target URL
  --headers              Header Information
  --sslinfo              SSL Certificate Information
  --whois                Whois Lookup
  --crawl                Crawl Target
  --dns                  DNS Enumeration
  --sub                  Sub-Domain Enumeration
  --dir                  Directory Search
  --wayback              Wayback URLs
  --ps                  Fast Port Scan
  --full                Full Recon

Extra Options:
  -nb                    Hide Banner
  -dt DT                 Number of threads for directory enum [ Default : 30 ]
  -pt PT                 Number of threads for port scan [ Default : 50 ]
  -T T                   Request Timeout [ Default : 30.0 ]
  -w W                   Path to Wordlist [ Default : wordlists/dirb_common.txt ]

```

```
-r      Allow Redirect [ Default : False ]
-s      Toggle SSL Verification [ Default : True ]
-sp SP  Specify SSL Port [ Default : 443 ]
-d D    Custom DNS Servers [ Default : 1.1.1.1 ]
-e E    File Extensions [ Example : txt, xml, php ]
-o O    Export Format [ Default : txt ]
-cd CD  Change export directory [ Default : ~/.local/share/finalrecon ]
-k K    Add API key [ Example : shodan@key ]
```

To get started, you will first clone the `FinalRecon` repository from GitHub using `git clone https://github.com/thewhiteh4t/FinalRecon.git`. This will create a new directory named "FinalRecon" containing all the necessary files.

Next, navigate into the newly created directory with `cd FinalRecon`. Once inside, you will install the required Python dependencies using `pip3 install -r requirements.txt`. This ensures that `FinalRecon` has all the libraries and modules it needs to function correctly.

To ensure that the main script is executable, you will need to change the file permissions using `chmod +x ./finalrecon.py`. This allows you to run the script directly from your terminal.

Finally, you can verify that `FinalRecon` is installed correctly and get an overview of its available options by running `./finalrecon.py --help`. This will display a help message with details on how to use the tool, including the various modules and their respective options:

Option	Argument	Description
<code>-h, --help</code>		Show the help message and exit.
<code>--url</code>	URL	Specify the target URL.
<code>--headers</code>		Retrieve header information for the target URL.
<code>--sslinfo</code>		Get SSL certificate information for the target URL.
<code>--whois</code>		Perform a Whois lookup for the target domain.
<code>--crawl</code>		Crawl the target website.
<code>--dns</code>		Perform DNS enumeration on the target domain.
<code>--sub</code>		Enumerate subdomains for the target domain.
<code>--dir</code>		Search for directories on the target website.
<code>--wayback</code>		Retrieve Wayback URLs for the target.
<code>--ps</code>		Perform a fast port scan on the target.
<code>--full</code>		Perform a full reconnaissance scan on the target.

For instance, if we want `FinalRecon` to gather header information and perform a Whois lookup for `inlanefreight.com`, we would use the corresponding flags (`--headers` and `--whois`), so the command would be:

```
Automating Recon

dbcyp0n@htb[/htb]$ ./finalrecon.py --headers --whois --url http://inlanefreight.com

-----
/\  _  \/\  \/\  "-.\  \/\  _  \/\  \
\ \  _\ \/\  \/\  \/\  \/\  _\ \/\  \
\ \_ \/\  \/\  \/\  \/\  \/\  \/\  \
\ \_ \/\  \/\  \/\  \/\  \/\  \/\  \
\ \_ \/\  \/\  \/\  \/\  \/\  \/\  \
```




Automating Recon

The screenshot shows a web browser displaying a list of RSS feeds for the website 'http://www.inlawfright.com'. The feeds are categorized by date, with the most recent being from 2021/03/06. The feeds include titles like 'New Update ...', 'Change Jersey's Email to jersey@inlawfright.com ...', 'New Update ...', 'New Update ...', 'New Update ...', and 'New Update ...'. The browser's address bar shows the URL 'http://www.inlawfright.com'.

+